

WEBSITE PRIVACY & TRACKING AUDIT

Target: [AnonyBra — anonymized] Date: 26/06/2026

1. EXECUTIVE SUMMARY

Privacy & cookie-compliance audit — AnonyBra, a German direct-to-consumer e-commerce store · 26/06/2026 · passive, client-side observation only

AnonyBra's website presents users with a cookie consent banner that offers granular, category-by-category controls, all switched off by default. In practice, however, these controls are largely cosmetic: a full set of analytics and advertising trackers — Google Analytics, Google Ads, the Meta Pixel, Microsoft Clarity (including session recording), Klaviyo, and Shopify analytics — already executed and stored identifiers on the user's device **before any consent was given**, while the banner was still displayed. This is the central finding of the audit and the most serious. Under §25 TDDDG and Art. 5(3) of the ePrivacy Directive, non-essential cookies and trackers may only be set after the user opts in; loading them on page load is unlawful regardless of how the banner is designed, and it directly contradicts what the consent interface tells the user is happening.

The audit identified two further, lower-severity issues with the consent mechanism itself. First, the entry banner offers no way to reject non-essential cookies on the first layer — accepting is a single click, while refusing requires opening a second settings panel, contrary to the principle that consent be as easy to refuse as to give. Second, within that settings panel the "Accept all" button is visually emphasised over "Reject all," nudging users toward consent.

It is worth noting what the site does correctly: consent is genuinely granular, no boxes are pre-ticked, strictly necessary cookies are properly distinguished, and a true "reject all" option does exist. The problems are therefore fixable without rebuilding the consent experience — they are matters of *behaviour* (trackers must wait for consent) and *placement* (reject must be as accessible as accept), not of missing functionality.

Overall risk: High, driven almost entirely by the pre-consent tracking, which is the issue most likely to attract a regulatory complaint or enforcement action.

Priority actions, in order:

1Gate all non-essential tags behind consent so that no analytics or advertising script fires until the user opts in (e.g. via Google Consent Mode and proper consent-management blocking). This resolves the High-severity finding.

Add an equally prominent "Reject all" button to the first-layer banner.

Give "Reject all" and "Accept all" equal visual weight in the settings pan

2. SCOPE & METHOD

This audit was conducted using passive, client-side observation only — inspecting cookies and network requests that a normal visitor's browser receives. No systems were scanned, accessed, or logged into. All evidence in this report has been sanitized before publication: cookie *values* (unique identifiers, session tokens, and any location or device data) have been redacted, as they constitute personal data and serve no analytical purpose. Only cookie *names* and *domains* are shown, since these are sufficient to identify which trackers are present and where they are set. The audited company has been anonymized as AnonyBra .

3. FINDINGS (one block per finding)

Finding 1 — Non-essential analytics and advertising trackers set before consent.

With the cookie banner still displayed and no consent given, the site had already set cookies from Google Analytics 4 (`_ga`, `_ga_*`), Google Ads (`_gcl_au`), the Meta Pixel (`_fbp`), Microsoft Clarity (`_clck`, `_clsk` — including session recording), Klaviyo (`_kla_id`), and Shopify analytics (`_shopify_analytics`, `_shopify_s`, `_shopify_y`). The presence of these cookies confirms the corresponding tracking scripts executed prior to any user interaction with the consent banner.

Why it's a risk: §25 TDDDG and Art. 5(3) ePrivacy permit storing or reading non-essential information on a user's device only after consent. Loading analytics and advertising trackers on page load — before consent — is unlawful regardless of banner design, and it directly contradicts the consent UI, which presents these categories as off by default.

Severity: High (headline finding).

Remediation: Gate all non-essential tags behind consent (e.g. via Google Consent Mode and proper CMP blocking) so nothing analytics- or marketing-related fires until the user opts in.

Finding 2 — Asymmetric consent: no "Reject all" on the first layer. The initial cookie banner offers only "Einstellungen" (Settings) and "Annehmen" (Accept). There is no option to reject non-essential cookies on this first layer — refusal requires opening the settings panel, i.e. at least one extra step, while acceptance is a single click.

Why it's a risk: Consent must be as easy to refuse as to give (GDPR Art. 4(11) & Art. 7; EDPB Guidelines 03/2022 on deceptive design patterns). Making rejection more effortful than acceptance is a recognised dark pattern; EU regulators — notably the French CNIL in enforcement against Google and Meta — have treated "accept on layer one, reject only on layer two" as a violation.

Severity: High.

Remediation: Add an equally prominent "Alles ablehnen" button directly to the first-layer banner, at the same level and visual weight as "Annehmen."

Finding 3 — Visual hierarchy nudges toward acceptance. In the settings panel, "Alles Akzeptieren" is a solid, dark, high-contrast button while "Alles ablehnen" is rendered as a lighter, lower-contrast outline. Both options exist on the same layer, but the styling draws the eye toward accepting.

Why it's a risk: Valid consent must be freely given. Visual nudging that steers users toward "accept" undermines the freely-given requirement and is flagged in the EDPB deceptive-design guidance. Lower severity than Finding 2 because the reject option is at least present on the same layer.

Severity: Low–Medium.

Remediation: Give "Alles ablehnen" and "Alles Akzeptieren" equal visual weight — same size, contrast, and styling.

COMPLIANT ASPECTS

- Granular control: users can consent by category (Funktionale, Performance, Targeting) rather than all-or-nothing.
- No pre-selected consent: all non-essential toggles default to OFF, as required. Pre-ticked boxes would be a serious violation; this site avoids it.
- Strictly necessary cookies ("Unbedingt erforderlich") are correctly non-toggleable and labelled "Immer erlaubt."
- A genuine "Alles ablehnen" option does exist within the settings layer — the issue (Finding 2) is its placement, not its absence

4. COOKIE INVENTORY

Cookie Name	Visible Domain	First/Third Party	Likely Purpose	Category
__kla_id	.nub...	First-Party	Klaviyo. Tracks users for email marketing and behavior flows.	Marketing
_ama	.nub...	First-Party	Amazon Pay or specific Shopify app tracking.	Functional / Analytics
_clk	.nub...	First-Party	Microsoft Clarity. Session ID for user behavior tracking/heatmaps.	Analytics
_clsk	.nub...	First-Party	Microsoft Clarity. Connects page views to a single session.	Analytics
_fbp	.nub...	First-Party	Meta/Facebook Pixel. Used for advertising and retargeting.	Marketing
_ga	.nub...	First-Party	Google Analytics. Primary cookie for distinguishing users.	Analytics
ga	.nub...	First-Party	Google Analytics 4 (GA4) session state cookie.	Analytics
ga	.nub...	First-Party	Google Analytics 4 (GA4) session state cookie.	Analytics
_gcl_a	.nub...	First-Party	Google AdSense/Ads. Used for tracking ad conversions.	Marketing
_ks_scriptVersionCheck...	nub...	First-Party	Internal script version caching (often related to Shopify apps).	Essential / Functional
_pandectes_gdpr	.nub...	First-Party	Pandectes App. Stores the user's cookie consent banner preferences.	Essential
_shop_app_es	.sho...	Third-Party	Shopify "Shop" app network.	Essential (for Shop

essential			Cross-site tracking for Shop Pay.	app)
_shopify_analytics	.nub...	First-Party	Shopify's native store analytics.	Analytics
_shopify_essential	.nub...	First-Party	Core Shopify platform operations and security.	Essential
_shopify_marketing	.nub...	First-Party	Shopify's native marketing and ad tracking API.	Marketing
_shopify_s	.nub...	First-Party	Shopify session cookie.	Essential
_shopify_y	.nub...	First-Party	Shopify analytics cookie (often paired with _shopify_s).	Analytics
cart	nub...	First-Party	Remembers the items added to the user's shopping cart.	Essential
cart_currency	nub...	First-Party	Remembers the selected currency (shows EUR in screenshot).	Functional
ig-fv	.nub...	First-Party	Third-party app data (Likely "Instafeed" or geolocation app).	Functional
ig-id	.nub...	First-Party	App-specific user ID.	Functional
ig-location	.nub...	First-Party	Stores user location data for dynamic content (shows Spain/Barcelona).	Functional / Personalization
ig-pv	.nub...	First-Party	App-specific page view tracking.	Analytics
ig-vars	.nub...	First-Party	Stores app variables/state.	Functional
localization	nub...	First-Party	Remembers the chosen language setting (shows DE for German).	Functional
shopify_client_id	nub...	First-Party	Unique Shopify device identifier used during checkout/analytics.	Essential / Analytics

5. REMEDIATION ROADMAP

Priority actions, in order:

1. **Gate all non-essential tags behind consent** so that no analytics or advertising script fires until the user opts in (e.g. via Google Consent Mode and proper consent-management blocking). This resolves the High-severity finding.
2. **Add an equally prominent "Reject all" button to the first-layer banner.**
3. **Give "Reject all" and "Accept all" equal visual weight** in the settings pan